

Требования информационной безопасности

ЦП РСФСР — мобильное приложение

Условное обозначение: РСФСР.МП.10.ТБ

1. Категория и уровень защищённости

Параметр	Значение
Категория объекта КИИ (ФЗ-187)	1 (наивысшая)
Уровень защищённости ИСПДн (ПП РФ №1119)	УЗ-1
Уровень защиты по ГОСТ Р 57580.1	4 (максимальный)
Класс ГИС (Приказ ФСТЭК №17)	K1
Соответствие OWASP MASVS	L2+

2. Применяемые нормативные документы

Документ	Применимость
ФЗ-152 «О персональных данных»	Защита ПДн пользователей
ФЗ-187 «О безопасности КИИ»	Категория 1
ФЗ-149 «Об информации»	Базовые требования
Положение Банка России №683-П	Защита информации в финансовых организациях
Положение Банка России №716-П	Операционный риск
Указание Банка России №6635-У	Инциденты ИБ
Положение Банка России №499-П	Идентификация клиентов
Положение Банка России №482-П	ЕБС
ГОСТ Р 57580.1-2017	8 направлений защиты
ГОСТ Р 34.10-2012	ЭП
ГОСТ Р 34.11-2012	Хеширование
ГОСТ Р 34.12-2015, ГОСТ Р 34.13-2015	Шифрование
Приказ ФСТЭК №239	КИИ 1 категории
Приказ ФСТЭК №17	ГИС класса K1
Приказ ФСТЭК №21	ПДн

3. Защита данных

3.1. Защита данных в покое (at rest)

Тип данных	Хранилище	Защита
------------	-----------	--------

Тип данных	Хранилище	Защита
Токены доступа, refresh-токены	iOS Keychain / Android Keystore / Windows Credential Locker	средствами ОС с биометрической защитой
Криптографические ключи	Secure Enclave / TEE	средствами устройства
Биометрические идентификаторы (но не векторы)	Защищённое хранилище	AES-256
Сертификаты УКЭП	Защищённое хранилище	средствами ОС
Кеш бизнес-данных	IndexedDB / SQLite	AES-256 с ключом из защищённого хранилища
Настройки приложения	LocalStorage	не шифруется (нечувствительные)

3.2. Защита данных в передаче (in transit)

- **TLS 1.3** с ГОСТ-сертификатами (КриптоПро TLS) для всех HTTPS-обменов.
- **mTLS** для критичных операций (выпуск ЦФА, подписание смарт-контракта).
- **Certificate pinning** на корневой СА уровня финансовой инфраструктуры РФ.
- **HSTS** для веб-режима (PWA).

3.3. Шифрование на уровне сообщений

Для критичных операций (выпуск ЦФА, подписание) применяется дополнительное шифрование payload на уровне приложения: - Алгоритм: ГОСТ Р 34.12-2015 («Кузнечик» / «Магма»). - Режим: ГОСТ Р 34.13-2015.

3.4. Подпись данных

- УКЭП пользователя: ГОСТ Р 34.10-2012 с длиной ключа 256/512 бит.
- Подпись хеш-функцией: ГОСТ Р 34.11-2012 (Стрибог).
- Сертификаты УКЭП выдаются Удостоверяющими центрами, аккредитованными Минцифры России.

4. Аутентификация и авторизация

4.1. Способы аутентификации

Первичная (вход в приложение)

- **ЕСИА** — OpenID Connect 1.0 с подтверждённой учётной записью.
- **ЕБС** — биометрическая идентификация (Положение №482-П).

Локальная (повторный вход)

- **Биометрия устройства** — Face ID / Touch ID / Windows Hello.
- **PIN-код** — 4–6 цифр, защищённое хранилище.

Критичные операции

- Двухфакторная аутентификация: SMS-код + биометрия.
- Подписание УКЭП.

4.2. Управление сессиями

- Срок жизни access-токена: 15 минут.
- Срок жизни refresh-токена: 30 дней.
- При длительной неактивности (10 минут) — повторная биометрическая аутентификация.
- При смене устройства — все предыдущие сессии аннулируются.

5. Защита приложения

5.1. Защита от компрометации устройства

- **Jailbreak/Root detection** — при обнаружении компрометации приложение:
 1. Выводит предупреждение пользователю.
 2. Блокирует функции выпуска ЦФА и подписания.
 3. Сохраняет режим только-чтение для существующих ЦФА.
 4. Отправляет инцидент в SOC.
- **Emulator detection** — отказ работы в эмуляторах (для продуктивной сборки).

5.2. Защита от обратной разработки

- **Code obfuscation** для всех платформ:
 - ProGuard / R8 для Android;
 - bitcode + Swift obfuscation для iOS;
 - .NET obfuscation для Windows;
 - JavaScript obfuscation для PWA.
- **Native code integrity** — проверка контрольных сумм при запуске.

5.3. Защита от MITM-атак

- Certificate pinning на двух уровнях: корневой CA и промежуточный.
- Запрет работы при подозрении на установку custom CA на устройстве.

5.4. Защита от скриншотов

- Включена защита от скриншотов для экранов:
 - Подписание смарт-контракта.
 - OTP-код.
 - Реквизиты для выплат.
 - Карточки активов с полным адресом.

5.5. Защита runtime

- **Anti-debug** — обнаружение отладчиков и frida-серверов.
- **Anti-hook** — проверка целостности ключевых функций.

- **Memory protection** — очистка секретов из памяти после использования.

6. Защита персональных данных (152-ФЗ)

6.1. Категория ПДн

Обрабатываются следующие категории ПДн (в соответствии со статьёй 3 152-ФЗ): - Иные категории — основная (ФИО, паспорт, ИНН, контакты, адрес). - Биометрические — при работе с ЕБС.

6.2. Согласия

- Согласие на обработку ПДн — оформляется через ЕСИА при первом входе.
- Возможность отзыва согласия — через раздел «Профиль → Безопасность → Удалить аккаунт».

6.3. Локализация

Все ПДн обрабатываются и хранятся исключительно на территории Российской Федерации в соответствии с пунктом 5 статьи 18 152-ФЗ.

6.4. Уровень защищённости

- УЗ-1 в соответствии с ПП РФ №1119.
- Соответствие приказу ФСТЭК России №21.

6.5. Уведомление Роскомнадзора

Оператор внесён в реестр операторов ПДн Роскомнадзора.

7. Реагирование на инциденты

7.1. Категории инцидентов

Категория	Описание	Время реагирования	Уведомление
Критический	Компрометация ключей УКЭП, массовая утечка ПДн	≤ 1 час	Банк России, ГосСОПКА, НКЦКИ
Высокий	Компрометация отдельного аккаунта, попытка несанкционированного выпуска ЦФА	≤ 4 часа	Банк России
Средний	Подозрительная активность	≤ 24 часа	Внутренний SOC
Низкий	Фоновые события	По расписанию	Внутренний SOC

7.2. Регламент уведомления

В соответствии с Указанием Банка России №6635-У: - Критические инциденты — в течение 1 часа. - Высокие — в течение 24 часов. - Полный отчёт — в течение 30 дней.

Уведомления через защищённый канал ВипНет в формате XML.

8. Аудит и мониторинг

8.1. Журналирование

Все ключевые события приложения логируются: - Авторизация (успех/неудача). - Подача актива. - Запуск выпуска ЦФА. - Подписание смарт-контракта. - Получение выплат. - Изменения профиля и настроек. - Изменения биометрических данных. - События безопасности (jailbreak, MITM, неудачная аутентификация).

8.2. Хранение журналов

- Operational logs: 13 месяцев.
- Security audit logs: 10 лет.
- Хранение на серверной части, не на устройстве.

8.3. SIEM-интеграция

Все события безопасности отправляются в SIEM-систему оператора (KOMRAD / MaxPatrol SIEM / R-Vision SIEM) в реальном времени.

9. Сертификация

9.1. Сертификаты ФСТЭК России

- Соответствие приказу №239 (КИИ 1 категории).
- Соответствие приказу №17 (К1).
- Соответствие приказу №21 (УЗ-1 ПДн).

9.2. Сертификаты ФСБ России

- Сертификация криптографических средств.

9.3. Сертификаты Банка России

- Соответствие положению №779-П (оператор ИС).
- Соответствие положению №683-П.
- Соответствие ГОСТ Р 57580.1 уровень 4.

9.4. Реестр Минцифры России

- Включение в Единый реестр российского ПО (ПП РФ №1236).

9.5. Регистрация в Роскомнадзоре

- Уведомление об обработке ПДн.

10. Контроль соответствия

- Внутренний аудит ИБ — ежегодно.
- Внешний пентест аккредитованной лабораторией — ежегодно.
- Внутренний Red Team — раз в полугодие.
- Проверка соответствия ГОСТ Р 57580.1 — ежегодно.
- Регуляторные проверки — по требованию ЦБ, ФСТЭК, ФСБ, Роскомнадзора.

Документ описывает требования информационной безопасности к мобильному приложению ЦП РСФСР и подлежит уточнению по результатам сертификационных испытаний.